

Runbook operativo – Seguridad y filtros (Detalle punto 10)

Sistema ASP.NET MVC (.NET Framework 4.8). La seguridad se aplica mediante autenticación, filtros y bitácora.

Alcance

- Capacitación sobre controles de acceso, filtros y prácticas seguras en la aplicación.

Componentes clave

- Autenticación: acciones sensibles requieren sesión válida (`Account/Login`, `Manage`, etc.).
- Filtro `[Autenticado]`: aplicado en controladores/acciones (ej. `GestionController.GestionEvaluacion`).
- Validación central: `Utilidades.ValidaSesion(Session, HttpContext)`; retorna parcial `Respuesta` si la sesión expiró.
- Bitácora: `Bitacora.NuevaEntrada` registra usuario/acción.

Roles y permisos

- Perfiles: Sistemas (todos los países), Regional (`paisesRegion`), Admin/otros (solo su país) según lógica de cada controlador.
- Mínimos privilegios: asignar roles según función operativa.

Flujo y buenas prácticas

1. Verificar sesión antes de acciones masivas o de administración.
2. Restringir vistas/controladores con `[Autenticado]` donde aplique.
3. Revisar bitácora para auditoría de acciones sensibles.
4. Mantener credenciales en vault; no en texto plano ni en documentos.
5. Validar configuración de `Web.config` (auth, SMTP, cadenas de conexión) en QA antes de producción.

Comprobaciones ante incidentes

- Si se redirige a `Respuesta` por sesión expirada: reautenticar y repetir la acción.
- Si no se aplica filtro: revisar atributos en controladores y la configuración de `FilterConfig`.
- Si bitácora no registra: verificar `Bitacora` y permisos de escritura donde almacene logs.

Acciones a evitar (riesgo de seguridad)

- No deshabilitar `[Autenticado]` en acciones que manipulan datos.
- No compartir cuentas de admin; usar cuentas nominativas.
- No exponer cadenas de conexión/SMTP en documentos o repos públicos.
- No editar `Web.config` en caliente sin pruebas; reinicia la app.

Exportar/Convertir a PDF

Redacta/ajusta este `.md` y conviértelo fuera de la app (ejemplo: `pandoc PlantillaMVC/Runbook.Seguridad.md -o Runbook.Seguridad.pdf`).